Phase D: STRIDE Threat Model

Week 05, Task 19 | AWS Lambda event-driven pipeline (S3 and SQS triggers)

Scope and method

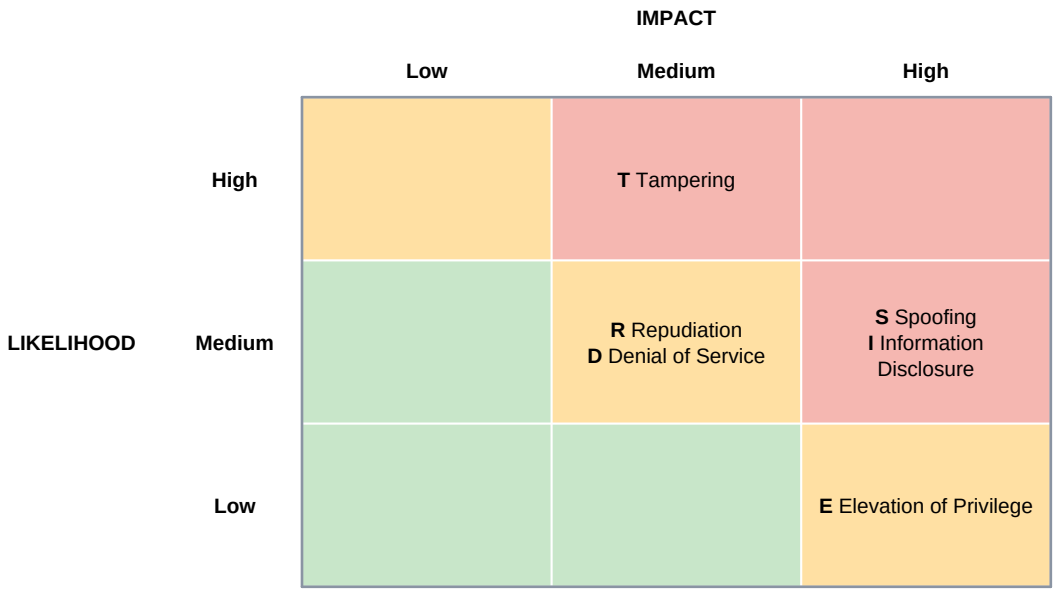
In scope: (1) S3 bucket *lambda-security-lab-titilayo* invoking *SecureLambdaDemo* under *LambdaExecRole*; (2) SQS queue *lambda-threat-model* (with dead-letter queue) invoking *SecureSQSProcessor* under its own least-privilege role. **Trust boundaries:** event sources to Lambda (resource-based policy), Lambda to AWS services (execution role and temporary STS credentials), and queue senders to the queue (queue policy).

Rating method: Likelihood and Impact are each rated Low (1), Medium (2) or High (3). Risk score = Likelihood x Impact. Score 6 to 9 = High, 3 to 4 = Medium, 1 to 2 = Low. Ratings are a qualitative judgement for this lab environment.

STRIDE threat table

STRIDE	Threat	Attack scenario in this environment	Likelihood	Impact	Risk	Mitigation
S Spoofing	**Compromised IAM role**	An attacker steals the temporary credentials of a function role (for example through a code flaw that leaks the session token from environment variables) or assumes a role with a loose trust policy, then acts as the function.	Medium	High	**High** (6)	Separate least-privilege role per function; trust policy limited to lambda.amazonaws.com; never log environment variables; alert on unusual AssumeRole and API activity (CloudTrail, GuardDuty).
T Tampering	**Malicious payloads in events**	A crafted, oversized or malformed message is sent to the SQS queue (or an object with a hostile key is uploaded to S3) and the function mishandles it, leading to injection or processing of untrusted data.	High	Medium	**High** (6)	Validate size, JSON structure and allow-listed values before use; never eval or shell out with event data; restrict sqs:SendMessage to named principals in the queue policy; send failures to a dead-letter queue.
R Repudiation	**Missing audit logs**	Nobody can prove who sent a message, changed a role policy or deleted an object because logging is off, short-lived or incomplete (S3 object-level actions are not in CloudTrail by default).	Medium	Medium	**Medium** (4)	Multi-region CloudTrail trail with log file validation; data events for sensitive buckets; log message IDs and request IDs; set CloudWatch log retention.
I Information Disclosure	**Overly broad permissions**	A role with wildcard permissions (such as s3:* on *) lets a function read or list far more than it needs. In Phase C the function listed all 9 buckets and deleted an object once s3:* was added.	Medium	High	**High** (6)	Scope actions and resource ARNs to exactly what is needed; review with IAM Access Analyzer; use permissions boundaries; alert on PutRolePolicy and AttachRolePolicy.
D Denial of Service	**Excessive invocations**	A flood of messages or uploads triggers many concurrent invocations, exhausting concurrency and raising cost; a poison message that keeps failing is retried repeatedly.	Medium	Medium	**Medium** (4)	MaximumConcurrency on the event source mapping and reserved concurrency; DLQ with maxReceiveCount; budget and CloudWatch alarms; modest batch size and timeout.
E Elevation of Privilege	**Cross-service trust abuse**	Another account's bucket or queue triggers the function (confused deputy), or a queue or function policy with a wildcard principal lets an untrusted party reach a more privileged role.	Low	High	**Medium** (3)	SourceArn and SourceAccount conditions on every invoke permission; no Principal "*" in queue or function policies; regular trust policy review with Access Analyzer.

Risk matrix



Rank	Threat	L	I	Score	Rating
1	**S** Compromised IAM role	M	H	6	**High**
2	**I** Overly broad permissions	M	H	6	**High**
3	**T** Malicious payloads in events	H	M	6	**High**
4	**R** Missing audit logs	M	M	4	**Medium**
5	**D** Excessive invocations	M	M	4	**Medium**
6	**E** Cross-service trust abuse	L	H	3	**Medium**

Legend: L = Likelihood, I = Impact (L/M/H = Low/Medium/High). Red = High risk, amber = Medium, green = Low.

Key findings

Highest priorities: Spoofing (compromised role), Information Disclosure (overly broad permissions) and Tampering (malicious event payloads) all score 6. They share one theme: whatever an attacker can influence in the event, or steal from the function, is limited only by the execution role.

Evidence from this lab: in Phase C, adding s3:* on * let the same function list every bucket in the account and delete the object that triggered it. CloudTrail recorded the ListBuckets calls as AccessDenied, Success, then AccessDenied again around the temporary policy change.

Controls built into the Phase D extension: a separate role for the SQS function with an inline policy scoped to the one queue ARN; input validation (size, JSON structure, allow-listed action); a dead-letter queue after 3 failed receives; a MaximumConcurrency limit of 2 on the event source mapping; and SourceArn/SourceAccount conditions on the S3 invoke permission.

Residual risk: object-level S3 actions are not logged without CloudTrail data events, so Repudiation stays Medium until data events are enabled for sensitive buckets. Cross-account trust (Elevation of Privilege) is Low in a single-account lab but should be reviewed before any production use.